sabsa-breb.pdf

ARQUITECTURA DE SEGURIDAD SABSA PARA PAGOS INMEDIATOS BRE-B

NovaPay S.A. // Gerencia de Pagos Inmediatos (Bre-B)

```
$ ./sabsa --empresa novapay --area bre-b
> capas contextual..component ...... ok
> matriz SABSA (xlsx) .............. ok
```


> equipo

Sergio Andrés Caceres Díaz
Over Haider Castrillón Valencia
Michael Steven Pinilla Mateus

Universidad del Rosario

MISIÓN DE LA EMPRESA

Universidad del Rosario

$ cat /etc/novapay/mision

> mision.txt

Facilitar que personas y comercios en Colombia muevan su dinero de forma **inmediata**, **segura** y **sin costo** desde el celular, protegiendo la **confianza** de los clientes como el activo principal de la compañía.

Quiénes: NovaPay S.A., compañía de financiamiento digital vigilada por la SFC.

Qué: Cuentas digitales, transferencias y pagos QR por Bre-B.

Por qué: Bre-B es interoperable, 24/7 y gratuito, una oportunidad para captar a quienes usan efectivo.

OBJETIVO DEL ÁREA: PAGOS INMEDIATOS BRE-B

> objetivo --area bre-b

Operar las transferencias y pagos inmediatos de NovaPay S.A. sobre Bre-B (**24/7**, liquidación en **menos de 20 s**), administrando las llaves de los clientes ante el Directorio Centralizado (DICE) y la liquidación en el MOL del Banco de la República, con fraude y disponibilidad dentro de los umbrales de la Junta.

alcance

- Inscripción y portabilidad de llaves (celular, cédula, correo, alfanumérica).
- Envío, recepción y pagos QR a comercios.
- Conciliación con el MOL, disputas y fraude.

metas (KPI)

- Disponibilidad $\geq$ 99,95 % mensual.
- Transacción extremo a extremo $<$ 20 s.
- Fraude $<$ 5 pb del valor transado.
- Cero incidentes de fuga de datos personales.

$ sabsa --layer contextual --view business --owner "Junta, CEO, VP Pagos, CISO"

WHAT — activos

- Servicio 24/7 y $<$ 20 s.
- Fondos y datos de clientes.
- Reputación y confianza.

WHY — amenazas

- Fraude APP, ATO (SIM swap, phishing), mulas.
- DDoS y caída de nube o enlace.
- Insiders, supply chain, ransomware.

HOW — procesos

- Onboarding / KYC.
- Gestión de llaves ante el DICE.
- Envío, recepción, QR, conciliación.

WHO — organización

- Junta, CEO, VP Pagos, CISO.
- Fraude, Riesgos (SARO), Datos.
- BanRep, nube, biometría, telcos.

WHERE — sitios

- Bogotá: operación y SOC.
- Nube: región principal + alterna.
- Enlace dedicado a BanRep.

WHEN — tiempo

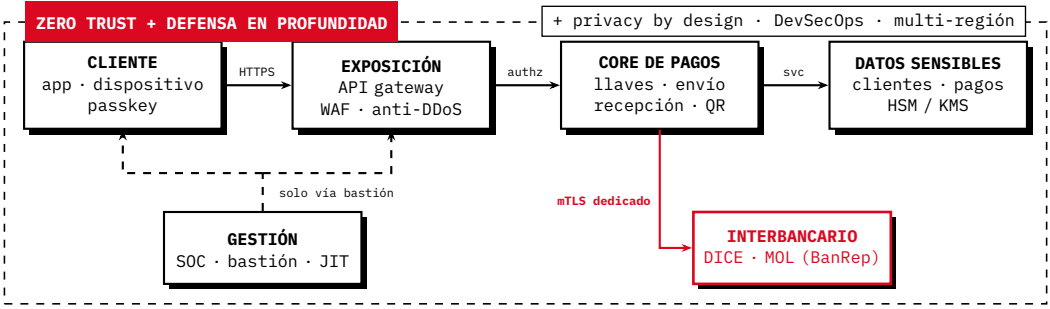
- Sin ventana de cierre.
- Picos 5× en quincena y primas.
- Reporte de incidentes a la SFC.

[SFC CE 007/2018 (hoy en la CBJ, CE 006/2025) · BanRep CRE DSP-465/2025]

Universidad del Rosario

$ sabsa --layer conceptual --view architect --owner "CISO"

atributos | **DISPONIBLE** | **CONFIDENCIAL** | **ÍNTEGRO** | **AUTENTICADO** | **NO REPUDIABLE** | **ANTIFRAUDE**

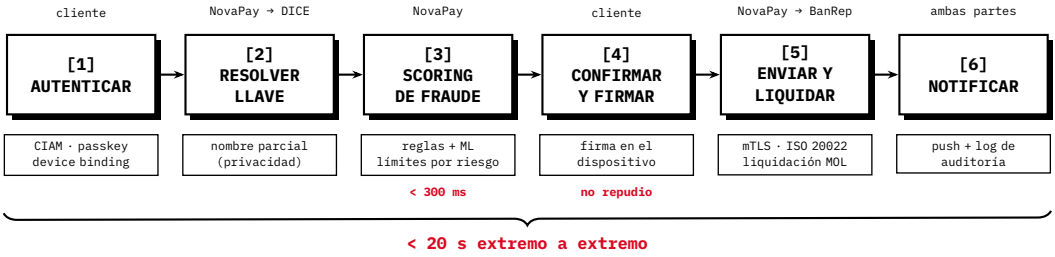


dueños VP Pagos (proceso) · CISO (riesgo ciber) · Gte. Fraude

riesgo NIST CSF 2.0 + SARO · revisión trimestral · KRI: fraude (pb), MTTD, MTTR

Universidad del Rosario

$ sabsa --layer logical --view designer --owner "Arquitecto de Seguridad"



PERFILES	cliente: sus llaves	agente: datos enmascarados	analista: retener/liberar	ingeniero: JIT	auditor: solo lectura
POLÍTICAS	MFA fuerte	bloqueo 24 h tras cambio de SIM	TLS 1.3 · mTLS · AES-256	sesión 5 min · token 10 min	

Universidad del Rosario

$ sabsa --layer physical --view builder --owner "Dir. Plataforma Cloud"

WHAT — datos

- Restringido: tokenizado.
- Confidencial: cifrado.
- Catálogo con dueño y retención.

WHY — reglas

- Reglas de fraude (velocidad, mula).
- Playbooks ATO, DDoS, ransomware.
- Parches críticos en 7 días.

HOW — mecanismos

- Passkeys FIDO2 + device binding.
- WAF, anti-DDoS, service mesh.
- HSM/KMS, tokenización, SIEM.

WHO — acceso

- SSO + llave FIDO2 interna.
- RBAC + ABAC (monto, horario).
- PAM con sesiones grabadas.

WHERE — red

- VPC por ambiente.
- Subred por dominio.
- 3 zonas + región alterna.

WHEN — tiempos

- **RTO 15 min, RPO 0.**
- Failover de zona < 1 min.
- Backups inmutables diarios.

Universidad del Rosario

$ sabsa --layer component --view tradesman --owner "Líder SecOps"

↓ internet · app · comercios

PERÍMETRO	Cloudflare: WAF · anti-DDoS · bots	API Gateway			
IDENTIDAD	Auth0 / Keycloak	Entra ID + YubiKey	CyberArk (PAM)		
PLATAFORMA	EKS 3 AZ + DR	Istio (mTLS)	Aurora	MSK (Kafka)	
CRIPTO	CloudHSM	KMS	HashiCorp Vault		
DETECCIÓN	Feedzai (fraude)	Sentinel (SIEM/SOAR)	GuardDuty		
PIPELINE	GitHub Actions	Semgrep	Snyk	Trivy	ZAP

agenda

> pentest trimestral
> escaneo semanal y en cada build
> DRP semestral
> tabletop anual de ransomware
> Vault: rotación diaria; certs 90 d
> NTP en todo nodo

- **Trazabilidad:** Cada producto de la capa Component se justifica hacia arriba hasta un requisito de negocio de Bre-B, de forma que ningún control queda sin dueño ni sin motivo.
- **Fraude antes que intrusión:** En pagos inmediatos el dinero no se puede reversar, por lo cual la autenticación fuerte, el device binding y el scoring en línea pesan tanto como el perímetro.
- **Disponibilidad como requisito de seguridad:** Un servicio 24/7 sin ventana de cierre obliga a diseñar la resiliencia (RTO 15 min, RPO 0) desde la capa conceptual y no como un añadido.
- **Cumplimiento integrado:** La SFC, el Banco de la República y la Ley 1581 se tratan como atributos de negocio y no como un checklist al final del proyecto.

SABSA = seguridad derivada del negocio, no agregada a la tecnología

$ sabsa --preguntas

¿PREGUNTAS?



NovaPay S.A. // Gerencia de Pagos Inmediatos (Bre-B)